STATE OF DELAWARE
**DEPARTMENT OF TECHNOLOGY AND INFORMATION**
801 Silver Lake Blvd.
Dover, Delaware 19904

| | | |
|---|---|---|
| **Doc Ref Number:** | SE-IAM-001 | **Revision Number:** 2 |
| **Document Type:** | Enterprise Policy | **Page:** 1 of 7 |
| **Policy Title:** | Identity and Access Management Policy | |

| | |
|---|---|
| **Synopsis:** | Management of identity and the authentication of users prior to obtaining access to State information is critical. |
| **Authority:** | Title 29 Chapter 90C Delaware Code, §9004C – General Powers, duties and functions of DTI "2) Create, implement and enforce statewide and agency technology solutions, policies, standards and guidelines, including as recommended by the CIO." |
| **Applicability:** | This policy is applicable to all users of the State of Delaware communications and computing resources. DTI is an Executive Branch Agency and has no authority over the customers in Legislative and Judicial Branches, as well as Local Education Agencies, and other Federal and Local Government entities that use these resources. However, all users, including these entities, must agree to abide by all policies, standards promulgated by DTI as a condition of access and continued use of these resources. |
| **Effective:** | 6/14/2022 |
| **Reviewed:** | 8/29/2025 |
| **Approved By:** | Chief Information Officer |
| **Sponsor:** | Chief Security Officer |

## TABLE OF CONTENTS


| Section | | Page |
|---|---|---|
| I. | POLICY | 2 |
| II. | DEFINITIONS | 4 |
| III. | DEVELOPMENT AND REVISION HISTORY | 6 |
| IV. | APPROVAL SIGNATURE BLOCK | 6 |
| V. | RELATED POLICIES AND STANDARDS | 7 |


## I. POLICY

**EXECUTIVE SUMMARY**
Identity is the critical foundational element for the security and protection of state data and information systems. It must uniquely identify, validate, and confirm the user or system accessing state communications and computing resources with non-repudiation. Authenticating users and systems before they gain access to State information and resources has never been more important.

**PURPOSE**
All state applications, systems, networks, and data access must ensure they are using a State Chief Security Office designated directory store to effectively identify access to state data. This policy defines the requirements for authentication, authorization, and accounting for access to state applications, systems, networks, and data. This policy also provides for the secure management of State of Delaware privileged accounts.

**POLICY STATEMENT**
1. State applications, systems, and networks controlling access to state constituent, employee, or financial data, must be authenticated, authorized, and accounted for through the state designated identity and access management solution.
2. State of Delaware internet facing applications that require the registration of constituent, resident, and/or visitors using their personally identifiable information, or

state applications that collect, store, or use personally identifiable information, must utilize the state designated identity and access management solution.

3. Identities used in the access to state applications, systems, networks, and data must be validated and proofed through a State Chief Security Office approved process or solution that ensures nonrepudiation of all activity.
4. The State identity and access management solution must protect the privacy of constituents', visitors', and residents' private identifiable information (PII). It must ensure they have:
   - The right to be forgotten and, to have their information deleted if they are no longer consuming state resources.
   - The right to know the applications accessing the identity information they have provided.
   - The right to not have their information sold or monetized.
   - The right to initiate the sharing or the transfer of their information to third party vendors.
5. All security-related activity must be logged with the required information (see standard/guideline) and upon request, the logs must be provided.
6. Identity and access management solutions must provide lifecycle management of all employees and contractors from position appointment, through position changes to eventual retirement or separation from State government.
7. Identity and access management solutions must enable the expedited and automated (where possible) removal of access for separating employees and contractors.
8. All Internet-facing applications must be compliant by 12/31/2023. All other state applications must be compliant by 12/31/2024.
9. The following areas are out of scope:
   - Authentication into mobile devices, legacy solutions like mainframes and Internet of Things (IOT) devices.
   - Authentication, authorization, and accounting requirements for ACF2 controlled applications, systems, and infrastructure.
10. Privileged accounts and secrets will be managed by the State of Delaware's Privileged Access Management (PAM) service, with waivers to this requirement being issued and approved by the DTI waiver process.
11. Privileged accounts' passwords/secrets/keys will be rotated automatically at least every 30 days, unless approved by the DTI waiver process.
12. The State Chief Security Office will maintain policy-setting control and authority over the PAM service, and its configuration and logging.
13. Human access to privileged accounts (such as through RDP, SSH, etc.) will be brokered and managed via a PAM session brokerage solution for tracking, logging, and chain of custody compliance.

a. Privileged accounts are to be in compliance with password/secret/key management by the dates outlined in item 16.
b. Privileged accounts are to comply with mandatory session management no later than 1 Year past items 16's prescribed compliance date.

14. Privileged scripts, scheduled jobs, and automations must be facilitated via a DTI-approved secrets-management platform provided via the PAM service.
15. Access to PAM-onboarded privileged accounts will be regularly audited by the State Chief Security Office (at least annually) to ensure that users are not retaining or amassing improper access to privileged accounts.
    a. Technical privileges granted to PAM-onboarded privileged accounts will be reviewed by the system owners (or responsible party) at least annually to ensure compliance with policy statements 10-15.
16. All privileged accounts must be compliant by 12/31/2028.
    a. Active Directory Accounts: Compliant by 07/01/2026
    b. Local System Accounts: Compliant by 04/01/2027
    c. Cloud / Web-App Accounts: Compliant by 12/31/2027
    d. Privileged Scripts and Automations: Compliant by 12/31/2028
17. If a system or account cannot align with these requirements, the requesting agency must pursue an exception through the DTI waiver process.

## II. DEFINITIONS

**ACF2** –a security suite that is often used on mainframes.

**Active Directory Privileged Account** – Any Active Directory account which retains explicit, delegated, or inherited permissions to write attributes or objects to the directory-system and/or its children, or any like-account which can change ACLs over said items.

**Authentication (AuthN)** – proving the person is who they say they are.

**Authorization (AuthZ)** – those things and only those things this authenticated person can do.

**Cloud & Web-Application Privileged Account –** Any state-owned account which can write production changes to a State of Delaware Cloud solution or Web-Managed Solution; or any account which can make tenant / installation-level changes to such a system.

**Directory store** – a location or database of user account information.

**Identity Access Management (IAM)** – a centrally managed authentication service.

**Internet-facing solution** – a type of solution with an interface that is accessible to the Internet.

**Internet of Things (IoT) devices** – hardware devices that have the ability to collect and exchange information over the Internet.

**Lifecyle Management** – the discipline of ensuring that the information is current and relevant. In the context of this policy, it is confirming that new users are added and users, who are no longer with the State, are removed from the appropriate directory stores.

**Local System Privileged Account** – Any account which is local to a computer system or device that retains explicit, delegated, or inherited permissions to alter system resources, system configurations, system-level directories, or can override the ACLs over another user's private directories (e.g. Linux-Root or Windows-Administrator).

**Mainframe** – a large high-speed computer.

**Managed Privileged Account** – An account meeting the definition of Privileged Account which is enrolled with the State's PAM service so as to be compliant with this policy document.

**Non-repudiation** – the process by which the sender must receive confirmation of delivery and the recipient must receive proof of sender's identity.

**Privileged Account** – An account or machine identity which possesses advanced or elevated permissions, beyond that of a standard account.

**PAM Service --** The State of Delaware's PAM Service is the product(s) by which privileged accounts, and access to them, are managed. Such a service is responsible for ensuring that Privileged Accounts comply with policies and are only accessed by authorized personnel, in accordance with said policies.

**PAM Session Broker –** A component of a privileged access management service which handles the proxying of management traffic involving privileged accounts. This solution provides sessions logging, chain of custody attestation, and anomaly detection.

**Privileged Secrets –** Accounts that do not use traditional username and passwords/phrases for authentication, but instead use an ID and secret pair. Such secrets, if they link to IDs with privileged-account-permissions, are defined as privileged accounts.

**Standard Account** – A user account or machine identity which does not possess advanced or elevated permissions; such an account might be used for reading and sending email, writing text documents, or reading files exposed to generic user accounts.

**Unmanaged Privileged Account** – An account meeting the definition of Privileged Account which is not enrolled with the State's PAM service due to a technical exemption or pre-approved waiver of compliance.

## III. DEVELOPMENT AND REVISION HISTORY

| Date | Revision |
|---|---|
| 6/14/2022 | Rev 0 – Initial version |
| 7/18/2022 | Rev 1 – Added definition section |
| 11/4/2024 | Rev 1 - Removed a reference to the Technology Investment Council |
| 8/29/2025 | Rev 2 – Added the State's Privilege Access Management service |

## IV. APPROVAL SIGNATURE BLOCK

| Name & Title: | Date: |
|---|---|
| Gregory Lane<br>State Chief Information Officer | 10/01/2025 |

## V. RELATED POLICIES AND STANDARDS

Identity and Access Management Standard
Identity and Access Management Guidelines